

2. Análisis de Riesgos

2.1 Metodología de análisis

Para la identificación y evaluación de riesgos se utilizó una metodología basada en la gestión de riesgos propuesta por ISO 27001 y adaptada al esquema de evaluación de Pirani Risk. El análisis se realizó considerando los activos de información identificados durante el relevamiento, las amenazas a las que se encuentran expuestos y las vulnerabilidades observadas en los procesos de la organización.

La valoración de los riesgos se efectuó mediante una matriz de probabilidad e impacto de cinco niveles. La probabilidad fue evaluada en una escala de 1 (insignificante) a 5 (frecuente), mientras que el impacto fue valorado en una escala de 1 (insignificante) a 5 (catastrófico).

El riesgo inherente se obtuvo multiplicando la probabilidad por el impacto, permitiendo clasificar cada riesgo según los siguientes criterios:

- Bajo: 1 a 4
- Medio: 5 a 9
- Alto: 10 a 16
- Crítico: 17 a 25

La representación gráfica de estos resultados se realizó mediante un mapa de calor que permite visualizar rápidamente los riesgos prioritarios para la organización.

2.2 Riesgos identificados

Durante el relevamiento se identificaron diez riesgos relevantes asociados a la gestión de la información de Vitalis.

R1 – Acceso no autorizado a la base de alumnos

Se identificó como activo crítico la base de datos de alumnos almacenada en archivos Excel. La ausencia de controles de acceso y permisos específicos aumenta significativamente la posibilidad de acceso indebido a información personal de los clientes. Este riesgo fue clasificado como **Crítico** debido a su elevada probabilidad e impacto.

R2 – Pérdida total de información por fallas de hardware

La organización depende principalmente de archivos Excel para gestionar información operativa y financiera. La falta de mecanismos formales de respaldo genera un elevado riesgo de pérdida total de información ante fallas de equipos o corrupción de archivos. Este riesgo fue clasificado como **Crítico**.

R3 – Manipulación interna de pagos y liquidaciones

La información financiera y los registros de pagos carecen de mecanismos de auditoría o trazabilidad que permitan identificar modificaciones realizadas por usuarios. Esto podría facilitar errores o fraudes internos que afecten la integridad de la información financiera. Este riesgo fue clasificado como **Crítico**.

R4 – Infección por ransomware

La utilización de equipos administrativos con controles limitados de seguridad podría permitir la infección por software malicioso de tipo ransomware. Un incidente de este tipo provocaría la paralización de la operatoria administrativa y la indisponibilidad de la información. Este riesgo fue clasificado como **Crítico**.

R5 – Exposición de datos personales por error humano

La gestión manual de archivos y su posible compartición sin restricciones adecuadas incrementan el riesgo de exposición involuntaria de información personal de alumnos y profesores. Este riesgo fue clasificado como **Alto**.

R6 – Errores contables por carga manual de información

El proceso de registración de pagos y liquidaciones se realiza manualmente mediante hojas de cálculo. Esta modalidad incrementa la probabilidad de errores en la carga de datos y posibles inconsistencias financieras. Este riesgo fue clasificado como **Alto**.

R7 – Robo o pérdida de dispositivos

La pérdida o robo de equipos utilizados para la administración podría generar acceso no autorizado a información sensible si los dispositivos no cuentan con mecanismos de cifrado o protección adecuados. Este riesgo fue clasificado como **Alto**.

R8 – Eliminación accidental de archivos

La ausencia de controles de versionado y recuperación facilita la pérdida accidental de documentos críticos para la operación diaria. Este riesgo fue clasificado como **Alto**.

R9 – Modificación no autorizada de cronogramas y actividades

La planificación de actividades y horarios se encuentra almacenada en archivos susceptibles de ser modificados sin mecanismos formales de validación o autorización. Este riesgo fue clasificado como **Medio**.

R10 – Dependencia operativa de archivos Excel

La centralización de la información crítica en archivos Excel genera una elevada dependencia tecnológica. La corrupción o indisponibilidad de estos archivos podría afectar directamente la continuidad operativa de la organización. Este riesgo fue clasificado como **Crítico**.

2.3 Resultados obtenidos

El análisis permitió identificar una elevada concentración de riesgos en los niveles más altos de criticidad.

De los diez riesgos evaluados:

- 5 riesgos fueron clasificados como Críticos.

- 4 riesgos fueron clasificados como Altos.
- 1 riesgo fue clasificado como Medio.
- No se identificaron riesgos de nivel Bajo.

Los resultados evidencian que la principal exposición de la organización se encuentra relacionada con la gestión manual de la información mediante archivos Excel, la ausencia de controles formales de seguridad, la falta de mecanismos de respaldo y la inexistencia de controles de acceso adecuados.

2.4 Conclusión del análisis

Los resultados obtenidos demuestran que Vitalis presenta un nivel de exposición significativo frente a amenazas que pueden afectar la confidencialidad, integridad y disponibilidad de la información. Los riesgos críticos identificados requieren la implementación prioritaria de controles de seguridad orientados a la protección de datos personales, gestión de accesos, respaldo de información, monitoreo de cambios y continuidad operativa.